



PROFESOR:

Alexis Moisés Montaño Araujo

MATERIA:

DBA

ALUMNO

José Mario Rivera Félix

GRUPO:

4 – 1

Informe

1. Introducción

En este laboratorio se abordaron diferentes mecanismos para proteger la información almacenada y transmitida mediante PostgreSQL. El objetivo fue comprender los riesgos de guardar contraseñas en texto claro, la importancia de cifrar los datos sensibles, la protección de las conexiones mediante TLS y la gestión segura de las claves criptográficas.

Estas medidas son importantes porque una configuración adecuada de usuarios y permisos no garantiza por sí sola la seguridad de la información. También es necesario utilizar mecanismos criptográficos que reduzcan el riesgo de exposición ante accesos no autorizados.

2. Protección de credenciales

El texto claro es información que puede leerse directamente sin necesidad de realizar ninguna operación adicional. Si una contraseña se almacena de esta manera, cualquier persona que consiga consultar la tabla puede conocerla.

Un hash es el resultado de aplicar una función criptográfica a una contraseña. Para proteger contraseñas se puede utilizar bcrypt mediante las funciones cryp y gen_salt de PostgreSQL, disponibles con la extensión pgcrypto. Este mecanismo permite comprobar una contraseña sin almacenar directamente su valor original. Además, el uso de una sal aleatoria hace que una misma contraseña pueda generar hashes diferentes.

El cifrado, por otra parte, permite transformar información para que no pueda leerse sin la clave correspondiente. A diferencia del hash, el cifrado está diseñado para que los datos puedan recuperarse mediante el descifrado cuando se cuenta con la clave adecuada.

Por lo tanto, para almacenar contraseñas es recomendable utilizar un algoritmo de hash diseñado específicamente para ellas, mientras que el cifrado es apropiado para datos que necesitan recuperarse posteriormente.

3. Protección de datos sensibles

Durante el laboratorio se analizaron diferentes mecanismos de protección según el tipo de información.

Las contraseñas deben almacenarse mediante un hash seguro, como bcrypt, en lugar de texto claro. Los datos personales, como el RFC, pueden protegerse mediante cifrado cuando se requiere mantener su confidencialidad y recuperarlos posteriormente. La información financiera también necesita cifrado y permisos restrictivos debido a su sensibilidad.

Las claves criptográficas deben mantenerse separadas de las tablas y de los scripts SQL, almacenándose en un sistema seguro de gestión de secretos o claves. Por último, los archivos de respaldo deben protegerse mediante cifrado, almacenamiento seguro y controles de acceso.

Cada mecanismo cumple una función distinta y debe combinarse con una configuración adecuada de permisos para proporcionar una protección más completa.

4. TLS

TLS es un protocolo que protege las comunicaciones entre un cliente y un servidor. Su función es reducir el riesgo de que terceros puedan leer o modificar la información mientras viaja por la red. La validación del certificado del servidor también permite comprobar su identidad y reducir el riesgo de conectarse a un servidor falso.

5. Gestión de claves

Las claves criptográficas permiten cifrar y descifrar información. Si una clave se almacena junto con los scripts SQL, puede quedar expuesta a cualquier persona que tenga acceso al repositorio o a sus copias.

Publicar una clave puede permitir que terceros descifren la información protegida con ella. Por esta razón, las claves deben almacenarse en sistemas seguros de gestión de secretos, con acceso restringido y procedimientos de rotación y revocación.

Si una clave se publica accidentalmente en GitLab, debe considerarse comprometida y reemplazarse. Eliminarla del archivo no garantiza que desaparezca del historial de versiones o de las copias existentes.

6. Resultados

Durante el laboratorio se creó una tabla de ejemplo que almacenaba una contraseña en texto claro para observar sus riesgos. También se trabajó con `pgcrypto` y las funciones `crypt()` y `gen_salt('bf')` para generar hashes de contraseñas.

Se estudió la diferencia entre el hash de una contraseña y el cifrado reversible de datos. Asimismo, se revisaron los riesgos de exponer claves criptográficas en scripts SQL y repositorios, y se analizaron los mecanismos de protección de información almacenada, comunicaciones y respaldos.

Finalmente, se revisó la consulta de PostgreSQL que permite comprobar el uso de SSL/TLS en la conexión actual y se elaboró una política mínima para proteger las claves criptográficas.

7. Problemas encontrados

Durante el trabajo se presentaron dudas relacionadas con la configuración de PostgreSQL, el uso de la extensión `pgcrypto` y la interpretación de los resultados de las consultas. Fue necesario distinguir entre la configuración general de SSL del servidor y el estado de cifrado de la conexión actual.

También se identificó que la disponibilidad de TLS y sus características dependen de la configuración del servidor, del cliente y del entorno utilizado. Por ello, los resultados deben verificarse directamente en la conexión y no suponerse únicamente por la configuración.

Nota: Esta sección debe ajustarse a los errores que realmente se presentaron durante la práctica. Si no ocurrió alguno de los problemas mencionados, se debe eliminar o sustituir por la dificultad real.

8. Conclusiones

El laboratorio permitió comprender que la seguridad de una base de datos requiere aplicar distintas medidas de protección. Las contraseñas deben almacenarse mediante hashes seguros; los datos sensibles que necesiten recuperarse pueden protegerse mediante cifrado; y las conexiones deben utilizar TLS con una validación adecuada del certificado del servidor.

También aprendí que la gestión de claves es fundamental, ya que una clave expuesta puede comprometer toda la información cifrada con ella. En un entorno productivo implementaría controles de acceso basados en el principio de mínimo privilegio, cifrado de datos y respaldos, conexiones TLS verificadas, almacenamiento seguro de claves, rotación de credenciales, auditorías y procedimientos de recuperación ante incidentes.

1. ¿Por qué una contraseña no debe almacenarse como texto claro?

Porque cualquier persona que consiga acceder a la tabla podría leer la contraseña original y utilizarla para entrar al sistema. Si el usuario reutiliza esa contraseña en otros servicios, el impacto puede ser todavía mayor. Por eso se recomienda almacenar un hash seguro de la contraseña.

2. ¿Por qué un hash no es equivalente a un cifrado?

Porque un hash está diseñado para ser una transformación unidireccional: no se utiliza una clave para recuperar el valor original. El cifrado, en cambio, permite recuperar la información mediante una operación de descifrado y la clave correspondiente.

3. ¿Por qué el cifrado de una columna no sustituye al control de acceso?

Porque el cifrado protege la confidencialidad de los datos, pero no determina quién tiene permiso para consultar o modificar una tabla. Si una aplicación descifra la información para un usuario no autorizado, los datos pueden quedar expuestos. Por ello, el cifrado debe combinarse con permisos y roles adecuados.

4. ¿Por qué TLS no sustituye a los mecanismos de autorización de PostgreSQL?

Porque TLS protege la comunicación entre el cliente y el servidor, pero no decide qué operaciones puede realizar un usuario. PostgreSQL debe seguir verificando las credenciales, roles y permisos para permitir o denegar el acceso a los datos.

5. ¿Qué ocurriría si una organización pierde una clave utilizada para cifrar información?

Si no existe una copia segura de la clave ni otro mecanismo de recuperación, la organización podría perder permanentemente el acceso a los datos cifrados. Por eso es importante contar con respaldos seguros de las claves y procedimientos de recuperación controlados.

6. ¿Qué ocurriría si una clave criptográfica se publica accidentalmente en GitLab?

Una persona con acceso a esa clave podría utilizarla para descifrar información protegida con ella. La organización debe considerar la clave comprometida, revocarla o reemplazarla, investigar la posible exposición y evaluar si es necesario volver a cifrar los datos.

7. ¿Por qué un repositorio privado no debe considerarse un almacén de secretos?

Porque los repositorios privados pueden ser accesibles para colaboradores, integraciones y sistemas automatizados. Además, las claves pueden permanecer en el historial de versiones, copias locales o respaldos incluso después de eliminarse del archivo. Los secretos deben guardarse en un sistema especializado con controles de acceso y auditoría.

8. ¿Qué diferencia existe entre proteger información almacenada y proteger información durante su transmisión?

La protección de información almacenada, también llamada protección en reposo, busca evitar que personas no autorizadas lean los datos guardados en discos, tablas o respaldos. La protección durante la transmisión busca impedir que terceros intercepten o alteren la información que viaja entre un cliente y un servidor. El cifrado de datos almacenados y TLS son mecanismos que atienden necesidades diferentes.

9. ¿Por qué la gestión de claves es tan importante como el algoritmo criptográfico?

Porque un algoritmo seguro no protege adecuadamente la información si la clave es fácil de adivinar, se encuentra expuesta o está disponible para personas no autorizadas. Una clave comprometida puede permitir descifrar los datos aunque el algoritmo sea robusto. Por eso se deben proteger su almacenamiento, acceso, rotación, respaldo y revocación.

10. ¿Qué mecanismo adicional implementarías en una organización para proteger los respaldos de las bases de datos?

Implementaría cifrado de los respaldos, almacenamiento en una ubicación separada y segura, controles de acceso estrictos y una gestión independiente de las claves de

cifrado. También realizaría pruebas periódicas de restauración para comprobar que los respaldos se pueden recuperar y que las claves necesarias siguen disponibles.